

Semana 10: Cross-Site Scripting (XSS)

O objetivo do trabalho desta semana é perceber em detalhe uma das categorias de ataques clássicos a aplicações Web, denominada por Cross-Site Scripting (XSS). O exercício foca-se em replicar o ataque famosamente conhecido como [Samy Worm](#).

Setup

Seguiremos o tutorial no link https://seedsecuritylabs.org/Labs_20.04/Web/Web_XSS_Elgg/. O setup de cada SEED Lab é feito utilizando o Docker. Siga os seguintes passos:

0. Garanta que tem o [Docker](#) instalado.
1. Edite o ficheiro `/etc/hosts` (com `sudo`) e acrescente uma nova entrada DNS

```
10.9.0.5    www.seed-server.com
```

2. Descarregue os ficheiros auxiliares necessários em [Labsetup.zip](#) e descompacte o ficheiro zip para uma pasta.
3. Dentro da pasta descomprimida, construa e execute os containers Docker com os seguintes comandos:

```
docker compose build
docker compose up
```

4. Aceda ao URL `www.seed-server.com` no seu browser. Deve ver a página inicial do site "Elgg For SEED Labs".

[!NOTE] Caso tenha um computador Mac com processador Arm, utilize ao invés o ficheiro [Labsetup-arm.zip](#).

[!NOTE] Caso tenha um computador Mac, o Docker funciona de forma ligeiramente diferente. Antes do passo 3, deve associar o IP do servidor web do container (fixo na configuração do Docker) ao seu host. Para isso, corra o comando

```
sudo ifconfig lo0 alias 10.9.0.5
```

e altere o ficheiro `docker-compose.yml` para conter adicionalmente

```
services:
  elgg:
    ...
    ports:
      - "10.9.0.5:80:80"
```

HTTP Requests

Para este exercício vai ser necessário inspecionar os HTTP requests feitos pela página. O SEED Lab recomenda o uso do plugin HTTP Header Live para o Firefox. Podem instalar este plugin ou um similar para outro browser, ou utilizar diretamente as Developer Tools do browser para o efeito.

Tarefas Base

Resolva as Tasks 1-4 do guião.

QUESTÕES: Q1 & Q2

Responda às questões 1 e 2 da Task 4 do guião.

QUESTÃO: Q3

Há várias modalidades de ataques XSS (Reflected, Stored ou DOM). Em qual/quais pode enquadrar este ataque e porquê?

Tarefas Extra

Resolva a Task 7 do guião, que exemplifica a utilização de Content Security Policy (CSP), uma das contramedidas mais robustas que podem ser adotadas por uma aplicação web (em conjunto com o browser) para evitar ataques de XSS.

QUESTÃO: Q4

Quais as diferenças entre os 3 websites de exemplo (`www.example32[a|b|c].com`)? Como pode explicar essas diferenças com base na sua configuração de CSP?